Social Engineering

DD2395/DD2391 Sonja Buchegger

Today

A. What is social engineering?

B. Why worry about social engineering?

C. Who is susceptible to social engineering?

D. What do social engineers want?

E. How do social engineers work?

F. What can we do about it?

Today

A. What is social engineering? Attacks exploiting human behavior, not system vulnerabilities.

B. Why worry about social engineering? Entry point.

C. Who is susceptible to social engineering? Everyone.

D. What do social engineers want? The most bang for the buck.

E. How do they work? Strategies exploiting human traits.

F. What can we do? Some training, some tech, much culture.

How Social Engineers Work

The social engineer employs the same persuasive techniques the rest of us use every day. We take on roles. We try to build credibility. We call in reciprocal obligations. But the social engineer applies these techniques in a manipulative, deceptive, highly unethical manner, often to devastating effect.

--Brad Sagan, social psychologist

Social Engineering

Some of the examples in the slides are taken from:

The Art of Deception by Kevin Mitnick

See also: The Art of Intrusion

What for?

- Industrial spying
- Access to resources, directly and indirectly. Trend: ransomware.
- Data theft
- Identity theft

Why should we worry (more!) about social engineering?

- Many (or most) attacks start by exploiting people's behavior, via social engineering or human error.

Why do we fall for it?

- Manipulation strategies exploiting human traits, habits, cultural expectations.
- Unrealistic assumptions.
- Added technical advances that make it hard for us to distinguish fake from real.

Why do we fall for it?

- Manipulation strategies exploiting human traits, habits, cultural expectations.
- Unrealistic assumptions.
- Added technical advances that make it hard for us to distinguish fake from real.

Phases

- Research
- Pretexting, develop rapport and trust
- Get data (exploit trust)
- Keep connections
- Combine data
- Use it

Techniques

- Trappings of role
- Credibility
- Forcing the target into a role (altercasting)
- Distracting from systematic thinking
- Momentum of compliance
- Bury questions
- Get pieces from different sources

More Techniques

- Read victim's openness
- Test with personal information
- Back off, don't burn the source
- Create then fix a problem

Exploits

- The desire to help
- Attribution
- Liking
- Fear
- Reactance
- Reciprocity
- Dynamics of doing a favor

Example Scenarios

- Prepare to answer these questions:
- What is happening? (Overall and the potential effect)
- How does the social engineer get information/access?
- How could this have been avoided?

Vishing example

- vishing example [2.5 min YouTube]

Flying out

“Hi,” the voice at the other end of the line says. “This is Tom at Parkhurst Travel. Your tickets to San Francisco are ready. Do you want us to deliver them, or do you want to pick them up?”

“San Francisco?” Peter says. “I'm not going to San Francisco.”

“Is this Peter Abels?”

“Yes, but I don't have any trips coming up.”

“Well,” the caller says with a friendly laugh, “you sure you don't want to go to San Francisco?”

“If you think you can talk my boss into it...” Peter says, playing along with the friendly conversation.

“Sounds like a mix-up,” the caller says. “On our system, we book travel arrangements under the employee number. Maybe somebody used the wrong number. What's your employee number?”

Peter obligingly recites his number. And why not? It goes on just about every personnel form he fills out; lots of people in the company have access to it – human resources, payroll, and, obviously, the outside travel agency. No one treats an employee number like some sort of secret. What difference could it make?

Why do we fall for it?

- Manipulation strategies exploiting human traits, habits, cultural expectations.
- Unrealistic assumptions.
- Added technical advances that make it hard for us to distinguish fake from real.

Unrealistic assumptions

If we have unrealistic assumptions about social engineering, we increase the probability of revealing information, which creates security problems. For example:

- I'm not important enough to be a target.
- This piece of information is not important to be harmful if leaked.
- If I say no, I create problems.
- If I get phished, it reflects on my intelligence.
  - Variant A: I’ll better not tell anyone.
  - Variant B: I’m too smart to fall for social engineering.

Unrealistic assumptions

If we have unrealistic assumptions about social engineering, we increase the probability of revealing information, which creates security problems. For example:

- I MAY NOT BE important enough to be a FINAL target, BUT ATTACKING ME CAN BE A STEP TO BUILD ON
- This piece of information is not important to be harmful if leaked BY ITSELF, BUT IT MAY BE USED TO GET MORE INFORMATION
- If I say no, I create problems BUT I MIGHT PREVENT BIGGER PROBLEMS.
- If I get phished, it reflects NOT on my intelligence BUT ON MY HUMANITY AND THE MANIPULATIVENESS OF THE ATTACKER.

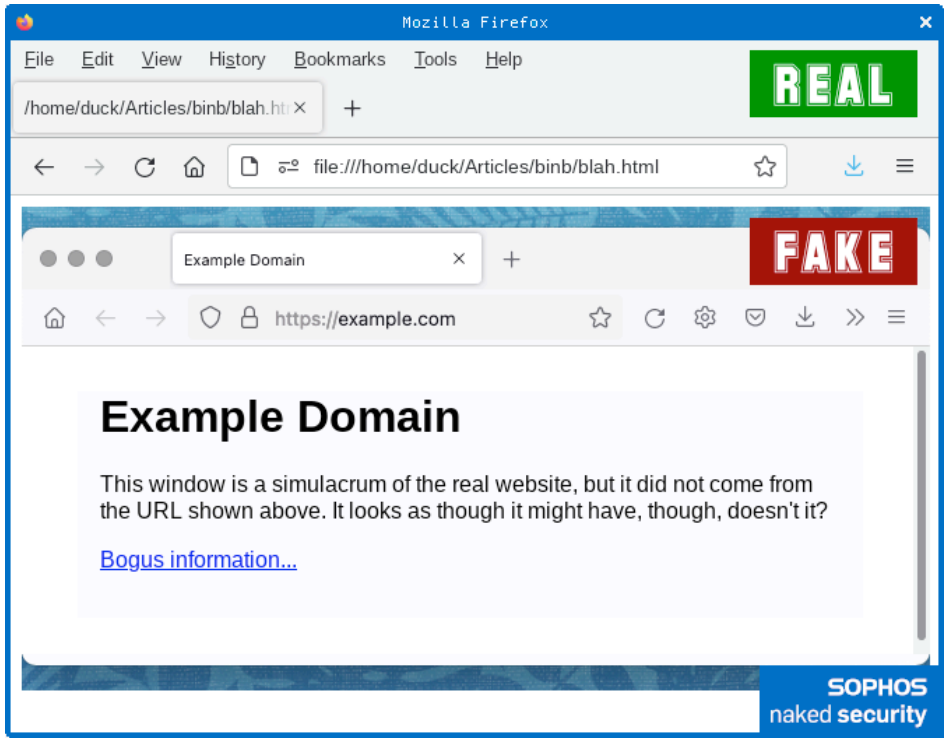
Why do we fall for it?

- Manipulation strategies exploiting human traits, habits, cultural expectations.
- Unrealistic assumptions.
- Added technical advances that make it hard for us to distinguish fake from real.

Technical methods, examples

- Browser-in-the-Browser popups, steam example
- Subdomains that look like legit domains

  www.microsoft.com.WEROIUOIUOEIRUOIUOIUT.reallybaddomain.com?OIU345
- Deepfakes
- Use html canvas + javascript + images to fake websites, last-mile-reassembly attack for social engineering [YouTube, 47m]



Just testing

"Hi, this is Peter Sheppard. I'm with Arbucle Support, the company that does tech support for your firm. I'd like to run a couple of tests with you, he said. "I'm able to see on my screen the keystrokes you type, and I want to make sure they're going across the network correctly. So every time you type a stroke, I want you to tell me what it is, and I'll see if the same letter or number is appearing here. Okay?"

After a few moments, she told him, "I have the login screen, and I'm going to type in my ID. I'm typing it now--M...A...R...Y...D."

"Great so far," he said. "I'm seeing that here. Now, go ahead and type your password but don't tell me what it is. You should never tell anybody your password, not even tech support. I'll just see asterisks here--your password is protected so I can't see it.

Listen, he went on, "we just installed an update that allow people to change their passwords. Would you be willing to take a couple of minutes with me so I can see if we got it working right?

She was grateful for the help he had given her and readily agreed. Peter talked her through the steps of launching the application that allows a user to change passwords, a standard element of the Windows 2000 operating system. "Go ahead and enter your password," he told her. "But remember not to say it out loud."

When she had done that, Peter said, "Just for this quick test, when it asks for your new password, enter 'test123.' Then type it again in the Verification box, and click Enter."

He walked her through the process of disconnecting from the server. He had her wait a couple of minutes, then connect again, this time trying to log on with her new password. It worked like a charm, Peter seemed very pleased, and talked her through changing back to her original password or choosing a new one--once more cautioning her about not saying the password out loud.

Network outage

The First Call: Tom Delay

“Tom DeLay, Bookkeeping.”

“Hey, Tom, this is Eddie Martin from the Help Desk. We're trying to troubleshoot a computer networking problem. Do you know if anyone in your group has been having trouble staying on line?”

“Uh, not that I know of.”

“And you're not having any problems yourself.”

“No, seems fine.”

“Okay, that's good. Listen, we're calling people who might be affected ’cause it’s important you let us know right away if you lose your network connection.”

“That doesn't sound good. You think it might happen?”

“We hope not, but you'll call if it does, right?”

“You better believe it.”

“Listen, sounds like having your network connection go down would be a problem for you…”

“You bet it would.”

“… so while we're working on this, let me give you my cell phone number. Then you can reach me directly if you need to.”

“That'd be great. Go ahead.”

“It's 555 867 5309.”

“555 867 5309. Got it. Hey, thanks. What was your name again?”

“It's Eddie. Listen, one other thing—I need to check which port your computer is connected to. Take a look on your computer and see if there's a sticker somewhere that says something like 'Port Number'.”

“Hang on No, don't see anything like that.”

“Okay, then in the back of the computer, can you recognize the network cable.”

“Yeah.”

“Trace it back to where it's plugged in. See if there's a label on the jack it’s plugged into.”

“Hold on a second. Yeah, wait a minute – I have to squat down here so I can get close enough to read it. Okay – it says Port 6 dash 47.”

“Good – that’s what we had you down as, just making sure.”

- The Second Call: The IT Guy
- Two days later, a call came through to the same company's Network Operations Center.
- “Hi, this is Bob; I'm in Tom DeLay's office in Bookkeeping. We're trying to troubleshoot a cabling problem. I need you to disable Port 6-47.”
- The IT guy said it would be done in just a few minutes, and to let them know when he was ready to have it enabled.
- The Third Call: Getting Help from the Enemy
- About an hour later, the guy who called himself Eddie Martin was shopping at Circuit City when his cell phone rang. He checked the caller ID, saw the call was from the shipbuilding company, and hurried to a quiet spot before answering.
- “Help Desk, Eddie.”
- “Oh, hey, Eddie. You've got an echo, where are you?”
- “I'm, uh, in a cabling closet. Who's this?”
- "It's Tom DeLay. Boy, am I glad I got a hold of you. Maybe you remember you called me the other day? My network connection just went down like you said it might, and I'm a little panicky here.”
- “Yeah, we've got a bunch of people down right now. We should have it taken care of by the end of the day. That okay?”
- “NO! Damn, I'll get way behind if I'm down that long. What's the best you can do for me?”
- “How pressed are you?”
- “I could do some other things for right now. Any chance you could take care of it in half an hour?”
- “HALF AN HOUR! You don't want much. Well, look, I'll drop what I'm doing and see if I can tackle it for you.”
- “Hey, I really appreciate that, Eddie.”
- The Fourth Call: Gotcha!
- Forty-five minutes later...
- “Tom? It's Eddie. Go ahead and try your network connection.”
- After a couple of moments:“Oh, good, it's working. That's just great.”
- “Good, glad I could take care of it for you.”
- “Yeah, thanks a lot.”
- “Listen, if you want to make sure your connection doesn't go down again, there's some software you oughta be running. Just take a couple of minutes.”
- “Now's not the best time.”
- “I understand... It could save us both big headaches the next time this network problem happens.”
- “Well... if it's only a few minutes.”
- “Here's what you do...”
- Eddie then took Tom through the steps of downloading a small application from a Web site. After the program had downloaded, Eddie told Tom to double-click on it. He tried, but reported:“It's not working. It's not doing anything.”
- “Oh, what a pain. Something must be wrong with the program. Let's just get rid of it, we can try again another time.” And he talked Tom through the steps of deleting the program so it

Countermeasures

How can we prevent/stop social engineering attacks?

Countermeasures

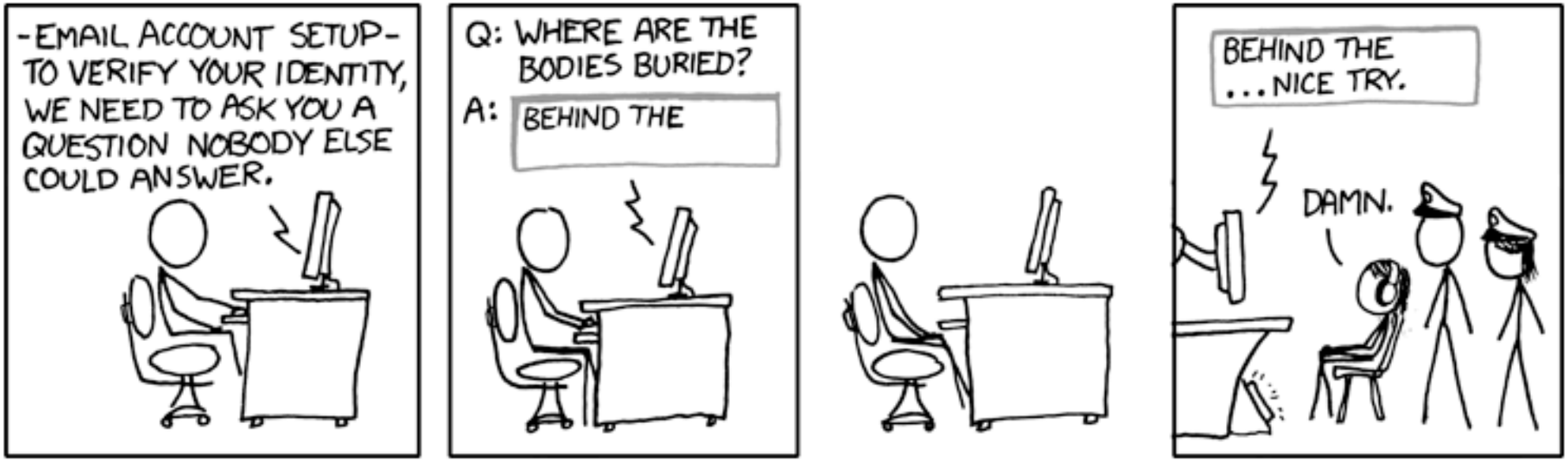
- Clear concise protocols that are enforced
- Awareness training, dispel myths (not important enough, too clever)
- Simple rules to define sensitive information
- Simple rule that ID required for restricted action
- Data classification policy
- Resistance training
- Testing by security assessment (but not setting traps)
- Politeness change, “NO” is OK

Countermeasures by technical means

- Filter BEFORE phishing mails, sites, messages, etc. get to the person.
- 2 factor authentication.
- Limit potential damage proactively by
  - following basic security design principles: least privilege, isolation, separation of duty, psychological acceptance, complete mediation, etc.,
  - patching vulnerabilities.

Security Question

|< < Prev Random Next > >|



|< < Prev Random Next > >|

Permanent link to this comic: http://xkcd.com/565/
Image URL (for hotlinking/embedding): http://imgs.xkcd.com/comics/security_question.png

Links

- analysis of network-outage example [13 min YouTube]
- the crying-baby vishing example [2.5 min YouTube]
- the musical phishing example [2 min YouTube]
- AI-facilitated social engineering example [CNN]
- exam example HT20, Part 2
- Swedish police celebrity campaign (news, in Swedish: videos, recording of vishing attempts (scroll down))